

CYBERSECURITY FUNDAMENTALS

Architecture, Threat Vectors, Defense-in-Depth & Incident Response

SYSTEM ARCHITECTURE • NETWORK SECURITY • APPLICATION SECURITY • SOC GUIDELINES

1. The Foundation: The CIA Triad & Core Principles

Every security policy, threat model, and cryptographic deployment aims to maintain the equilibrium of the three foundational security pillars:

Pillar	Core Objective	Key Mechanisms
Confidentiality	Prevent unauthorized disclosure of data in storage, transit, or compute.	AES-256, RSA/ECC, RBAC, Data Classification, TLS 1.3
Integrity	Guarantee that data has not been altered, tampered with, or forged.	SHA-256/SHA-3, HMAC, Digital Signatures, Blockchain/Ledgers
Availability	Ensure critical systems and services remain operational and accessible.	Redundancy, Auto-scaling, Failover clusters, DDoS Protection

2. Modern Security Architecture & Defense Models

- **Defense in Depth:** Employing multiple layered defenses so that if one security barrier is breached (e.g., perimeter firewall), secondary controls (e.g., endpoint detection, network micro-segmentation, database encryption) halt adversary movement.
- **Zero Trust Architecture (ZTA):** Operates on the premise: *"Never trust, always verify."* Every entity, packet, and user session is continuously authenticated, authorized, and validated regardless of whether the request originates from within the local intranet.
- **Principle of Least Privilege (PoLP):** Every process, user account, and service role must possess only the minimum privileges essential to perform authorized functions.
- **Network Microsegmentation:** Isolating application tiers, production databases, and user subnets using VLANs and software-defined boundaries to prevent lateral movement.

Zero Trust Architectural Triad

Strict Identity Verification (MFA & Risk-based Auth) + Dynamic Device Health Attestation + Explicit Least-Privilege Access Control.

3. Common Threat Vectors & Mitigation Strategies

Web Application Security (OWASP Top 10)

- **Injection Attacks (SQLi, Command Injection):** Occur when untrusted user input is concatenated directly into database interpreters or OS shells.

Remediation: Implement parameterized queries (PreparedStatements), Object-Relational Mappings (ORMs), and strict input validation schemas.

- **Broken Authentication & Session Hijacking:** Weak session lifetimes, lack of brute-force throttling, or missing credential storage salts.

Remediation: Enforce Argon2id/bcrypt hashing, cryptographic session tokens, and short session timeouts.

- **Cross-Site Scripting (XSS):** Injected scripts executed in the victim's browser session.

Remediation: Contextual output encoding, strict Content Security Policy (CSP), and HttpOnly flags on session cookies.

Network & System Infrastructure Threats

- **Man-in-the-Middle (MitM):** Eavesdropping or hijacking transit communication.

Remediation: Strict Transport Security (HSTS), Mutual TLS (mTLS), and DNSSEC.

- **Ransomware & Malware Vectors:** Propagation via malicious attachments, unpatched vulnerabilities (CVEs), or compromised supply chains.

Remediation: Robust EDR agents, immutable backups (3-2-1 backup rule), and application allow-listing.

- **DDoS (Distributed Denial of Service):** Volumetric and application-layer resource exhaustion.

Remediation: Anycast routing networks, rate-limiting, and Cloud WAF scrubbing centers.

4. Incident Response Lifecycle (NIST SP 800-61 Rev. 2)

1. **Preparation:** Hardening systems, conducting tabletop simulation drills, deploying monitoring sensors, and creating runbooks.
2. **Detection & Analysis:** Ingesting telemetry into a centralized SIEM/SOAR system, analyzing alerts, identifying indicators of compromise (IoCs), and evaluating scope.
3. **Containment:**
 - *Short-term:* Disconnecting infected hosts from subnets, invalidating tokens, and blocking command-and-control (C2) IPs.
 - *Long-term:* Applying temporary access filtering and creating forensically sound disk images.
4. **Eradication & Recovery:** Removing rootkits and unauthorized persistence hooks, rebuilding affected instances from trusted golden images, and restoring clean data.
5. **Post-Incident Activity (Lessons Learned):** Root-cause analysis (RCA), documentation audits, and updating threat models and firewall rules to prevent recurrence.

5. Essential Security Hardening Checklist

- ✓ Multi-Factor Authentication (FIDO2 / Hardware Security Keys preferred) enforced on all administrative interfaces.
- ✓ Centralized, cryptographically verified logging with forwarders streaming to a tamper-proof log repository.
- ✓ Automated patch and vulnerability management pipeline with rigorous CVE prioritization.
- ✓ All external ingress endpoints protected by Next-Gen Web Application Firewalls (WAF).
- ✓ Default ports, legacy protocols (Telnet, SMBv1, HTTP), and factory passwords completely disabled.
- ✓ Isolated, offline/immutable backups tested periodically for disaster recovery integrity.